

2024

2025

- **2026년 소프트웨어 보안약점
진단원 이수시험 안내서**

2027

2028



행정안전부



한국인터넷진흥원

목 차

1. 진단원 정의 및 자격기준

가. 진단원 정의	3
나. 진단원 자격기준	3

2. 2026년 진단원 이수시험 안내

가. 연간 일정	4
나. 신청 및 접수 안내	4
다. 이수시험 대비 안내	6
라. 이수시험 당일 안내	7
마. 합격자 발표 안내	9
바. 문의처	9

※ [붙임1] 이수시험 관련 자주 나오는 질문 (FAQ)	10
※ [붙임2] 이수시험 문제 예시	11
※ [붙임3] 소프트웨어 보안약점 기준	19

1

진단원 정의 및 자격기준

가 진단원 정의

- 소프트웨어 보안약점이 남아있는지 진단하여 조치방안을 수립하고 조치결과 확인 등의 활동을 수행하는 자

※ 행정기관 및 공공기관 정보시스템 구축·운영 지침 (행정안전부고시 제2025-1호)

나 진단원의 자격기준

1) 자격기준:

◦ 기본요건

- 6년 이상 소프트웨어 개발분야 업무를 수행한 자
- 3년 이상 소프트웨어 보안약점 또는 보안취약점 진단·분석업무를 수행한 자

◦ 교육요건

- 기본요건을 만족하고 기본교육을 이수한 자

2) 자격 취득 기준:

기본교육*을 수료하고 진단원 이수시험을 합격한 자

* **기본교육** : SW보안약점 진단원 기본과정(40시간, 5일)

3) 자격 유지기준:

자격 취득 후 다음 해(1월~12월)까지 자격 유지되며,

이후 매년 보수교육* 수료를 통해 자격 유지

* **보수교육** : 연 1회(8시간) 진행

소프트웨어 개발보안 지식의 지속적인 습득 및 기술능력 유지를 위한 교육

※ 보수교육 미수료 시 다음 해(1~12월)부터 자격 정지

단, 보수교육 수료 시, 자격 유지로 변경

2

2026년 진단원 이수시험 안내

가 연간일정

[표 1] 진단원 이수시험 및 접수일정

시험 차수	시험 일정	접수일정	취소 마감기한	합격 발표일	26년 진단원 기본(양성)과정 자동응시 대상
1차	8.8(토)	7.6(월) 10:00 ~ 7.10(금) 17:00 (5일)	7.31(금) 13:59	8.21(금)	1,2차 수료생
2차	10.31(토)	9.14(월) 10:00 ~ 9.18(금) 17:00 (5일)	10.16(금) 13:59	11.13(금)	3,4차 수료생

- 마감 이후 취소 요청하거나 시험 당일 무단 불참할 경우, 응시자는 응시 기회가 차감됨
- ※ 정원 충족 시 조기 마감될 수 있으며, 접수기간 내 신청자에 한해 시험 응시 가능
- 2026년 1·2차 수료자는 이수시험 1차,
- 2026년 3·4차 수료자는 이수시험 2차에 자동 응시되며, 별도 신청은 없어도 됨
- ※ 일정은 내부 사정에 따라 변경될 수 있으며, 변경 시 별도 공지 예정

나 신청 및 접수 안내

1) 응시자격

- ① 2025년 진단원 기본(양성)과정 교육 수료 후, 이수시험 응시 횟수 2회 이내인 자
 - ② 2026년 진단원 기본(양성)과정 교육 수료 후, 이수시험 응시 횟수 2회 이내인 자
- ※ 단, 진단원 기본(양성) 과정은 연 1회 수강 가능

2) 이수시험 기본 응시 횟수

- 총 2회 (자동응시 1회 + 선택응시 1회)
- 응시 횟수 예시

예시		응시 횟수
25년 수료자	25년 1회 자동응시 후, 불합격	2026년 1회 응시 가능
	25년 2회 응시 후, 불합격	2026년 응시 불가 (2026년 기본(양성)과정 재수료 후 응시 가능)

예시		응시 횟수
26년 수료자	기본(양성)과정 1,2차 수료자가 이수시험 1차에 불참할 경우	2027년까지 1회 응시 가능
	기본(양성)과정 3,4차 수료자가 이수시험 2차에 불참할 경우	2027년까지 1회 응시 가능
	1회 자동응시 후, 불합격	2027년까지 1회 응시 가능
	2회 응시 후, 불합격	2027년 기본(양성) 재수료 후 응시 가능

3) 접수방법

SW개발보안 교육 및 진단원 교육과정 신청 페이지(<https://swsca.kr/>)에서
일정 확인 후, **개별 신청**

4) 유의사항

- 시험에 응시할 수 없는 경우, **취소 마감기한 전까지 반드시 취소 요망**

- **자동 응시**의 경우,

실제 응시 여부와 관계없이 1회의 응시 기회가 차감됨

※ 가급적 해당 일정에 맞춰 시험 응시하는 것을 권장함

- **선택 응시**의 경우,

참석이 불가한 경우에는 취소 마감까지 반드시 취소 요망

※ 마감 기한 이후에 취소를 요청하거나,

시험 당일 무단으로 불참할 경우에는 응시 기회가 차감함

예) 이수시험 1차 선택 응시 신청자의 경우,

• 7.31(금) 13:59 이후에 취소하거나

• 8.8(토) 시험 당일 무단으로 불참할 경우 → 시험 응시 기회 1회 차감

다 이수시험 대비 안내

1) 종합점수 산출방식

이론시험(40%) + 실습시험(60%) 가중치

[표 2] 이수시험 종합점수 산출방식

구분	시간	문항	배점	과락	가중치
이론시험	60분	30문항	100점	60점 미만	40%
실습시험	100분	15문항	100점	60점 미만	60%

2) 합격기준

가중치에 따른 종합점수 70점 이상일 경우 합격 (과락: 60점 미만)

* 소수점 첫째 자리 기준 산정

예) 69.9점 불합격

3) 출제범위

SW개발보안 제도·기준, 보안약점 진단·제거기술 등

4) 참고자료

- 소프트웨어 보안약점 진단가이드 및 개발보안 가이드
- 진단원 기본(양성) 교재

5) 문제 구성

- 회차별 문제구성은 달리 적용될 수 있음

① 이론시험(60분)

[표 3] 진단원 이론시험 문제 구성

구성	내용	문항
객관형	• 4~5개 객관식 지문 중 선택	30

② 실습시험(100분)

[표 4] 진단원 실습시험 문제 구성

구성	내용	문항
서술형	• 보안약점 정·오탐 분석 및 보고서 작성	15

6) 참고사항

- 이수시험 중 ‘SW 보안약점 기준 명칭’이 제공됩니다.
- 2025년부터 **이론시험은 전면 객관형으로 변경**되었으며,
OMR 방식으로 진행됩니다. (컴퓨터용 사인펜 지참)

라 이수시험 당일 안내

[표 5] 시험 당일 진행일정

시간	일정
12:00 ~ 12:50	출입절차 진행 및 시험장 입실 완료
12:50 ~ 13:00	OT 및 이론시험 대기
13:00 ~ 14:00	이론시험 (60분)
14:00 ~ 14:20	휴식시간 (20분)
14:20 ~ 14:30	실습시험 대기
14:30 ~ 16:10	실습시험 (100분)

1) 공통 안내사항

- ① **12시 50분 이후 입실 및 응시가 불가**하며, 사전에 시험장 위치 및 시험장 입실 가능 시간을 숙지하시기 바랍니다.
- ② 좌석배치도에 따라 배정된 좌석에 착석하며, 배정 좌석 이외의 이동은 불가합니다.

③ 시험 준비물

신분증, 검은색 볼펜, 컴퓨터용 사인펜 지참

※ 연필 사용은 금지되며, 수정테이프는 현장에서 지급됩니다.

※ 인정 신분증: 주민등록증, 자동차 운전면허증, 장애인등록증, 여권,
당일 발급받은 모바일신분증

④ 시험 중 부정한 행위를 한 자는 당해 연도의 시험 응시가 중지되며, 이후 3년간 응시 자격을 얻을 수 없습니다.

- 시험 중 다른 수험자와 시험과 관련된 대화를 하거나 답안지를 교환하는 행위
- 시험 중 다른 수험자의 답안지 또는 문제지를 엿보고 답안을 작성하는 행위
- 다른 수험자를 위하여 답안을 알려주거나 엿보게 하는 행위
- 시험 중 시험문제 내용과 관련된 물건을 휴대하여 사용 또는 주고받는 행위
- 시험자 내외의 자료부터 도움을 받고 답안지를 작성하는 행위
- 다른 수험자와 성명을 바꾸어 제출하는 행위
- 대리시험을 치르거나 치르게 하는 행위
- 시험시간 중 통신기기 및 전자기기를 사용하여 답안지를 작성하거나 다른 수험자를 위하여 답안을 송신하는 행위
- 그 밖에 부정 또는 불공정한 방법으로 시험을 치르는 행위

⑤ 시험 시작 전 전자,통신기기(스마트폰, 스마트워치 등)를 제출해야 합니다.

⑥ 시험시간 중 및 휴식시간(10분) 중 전자,통신기기를 비롯한 교재, 참고자료 소지 및 사용이 적발될 경우 퇴실조치 및 당해시험은 무효처리 됩니다.

⑦ 휴식시간(20분) 중 본인 시험장, 화장실, 흡연장만 이용 가능하며, 이외 장소 방문 및 건물 밖 출입은 불가합니다.

⑧ 실습시험 답안 제출 후, 15시 30분 이후 퇴실 가능합니다. (종료 40분 전)

2) 시험 안내사항

① **시험 준비물을 반드시 확인 후 지참**하여야 응시 가능합니다.

② **시험장 입장 시 신분증 대조 및 소지품 점검**이 있으며, 시험위원의 안내에 따라야 합니다.

③ 반드시 **이론시험은 컴퓨터용 사인펜으로, 실습시험은 볼펜으로** 작성해야 합니다.

지정된 필기구 외에 작성한 답안은 채점하지 않으며, 0점으로 처리됩니다.

※ 실습시험 답지 작성 시 가능한 정자체 사용 바랍니다.

- ④ 시험 시작 전 **문제지 및 답안지의 이상 유무를 확인**하고, 이상이 있을 경우 **즉시 시험위원에게 조치**를 요청해야 합니다.
- ⑤ 시험 종료 후 **문제지, 답안지 및 기타 자료를 시험위원에게 모두 제출**해야 합니다.
- ⑥ 시험 중에는 문항에 대한 질문은 받지 않습니다. 문항에 대한 특이사항이나 궁금한 점이 있을 경우 답안지에 작성해주시면 채점에 반영하겠습니다.
- ⑦ 응시자의 개별 정답여부와 부분점수, 오답 내용은 별도로 공개하지 않습니다.

마 합격자 발표 안내

1) 합격자 발표 일정

① 시기

- 1차: 2026년 8월 21일(금)
- 2차: 2026년 11월 13일(금)

② 방식

- 이메일 개별 통보

※ 일정은 내부 사정에 따라 변경될 수 있으며, 변경 시 별도 공지할 예정입니다.

2) 합격증 배부 일정

① 시기

- 1차: 합격자 발표 후 2개월 이내
- 2차: 합격자 발표 후 2개월 이내

② 방식

- 개별 우편 발송

바 문의처

교육운영 사무국 ☎ 070-4352-1470 / edu@kisec.com)

붙임 1 이수시험 관련 자주 나오는 질문 (FAQ)

Q1 2026년 기본(양성)과정을 수료한 후, 자동응시 시험은 개별로 신청해야 하나요?

- 아닙니다.

기본(양성)과정 1,2차 수료자는 이수시험 1차, 3,4차 수료자는 이수시험 2차에 자동 응시 처리되므로, **별도 신청은 필요 없습니다.**

※ 교육 종료 전 자동응시 시험에 대한 참석 여부 조사 시 '참석'으로 응답해 주시면 됩니다.

- 단, 총 2회의 응시 기회 중 자동응시 1회는 실제 응시 여부와 관계없이 자동 차감됩니다.

※ 가급적 해당 일정에 맞춰 자동응시 시험에 응시하시는 것을 권장합니다.

- 선택응시 1회는 2027년까지 신청하실 수 있습니다.

Q2 응시 횟수를 모두 소진한 경우, 어떻게 해야 하나요?

- 2025년 기본(양성)과정 수료자는 2026년 양성과정을 재수료한 후,

2026년 기본(양성)과정 수료자는 2027년 양성과정을 재수료한 후,

응시 자격을 다시 획득하실 수 있습니다.

- 단, 진단원 기본(양성)과정은 연 1회만 수강 가능합니다.

예) 2026년 1차 교육을 수료한 경우, 같은 해 4차 교육 재수강은 불가하며,

2027년에 다시 신청 후 수강해야 합니다.

Q3 진단원 이수시험의 합격률은 어떻게 되나요?

- 진단원 이수시험의 합격률은 별도로 공개되지 않습니다.

Q4 시험 문제 중 SW 보안약점 기준을 정확하게 기재해야 하는 문제가 있나요?

- SW보안약점 기준은 시험 중 참고 자료로 배포해드립니다. 따라서, SW보안약점 기준에 대한 번호만을 서술하는 문제는 출제되지 않습니다. 다만, SW보안약점 기준에 대한 상세 내용은 사전에 숙지하셔야 원활한 답안 작성이 가능합니다.

Q5 진단원 시험에 합격했습니다. 합격증은 언제 어떻게 받을 수 있나요?

- 이수시험 1차 합격자 발표 후 2개월 이내 우편 등으로 개별 발송됩니다.

- 이수시험 2차 합격자 발표 후 2개월 이내 우편 등으로 개별 발송됩니다.

붙임 2 이수시험 문제 예시

1. 이론시험

가. 객관형 : 4~5개 객관식 지문 중 선택

1) 문제

아래 소스코드에 대한 보안약점의 설명으로 잘못된 것은 무엇인가?

```
String lastLogin = request.getParameter("last_login");
if (lastLogin == null || "".equals(lastLogin)) { return; }
lastLogin = lastLogin.replaceAll("[WwNn]", "");
Cookie c = new Cookie("LASTLOGIN", lastLogin);
c.setMaxAge(60*60*24*365);
c.setSecure(true);
c.setHttpOnly(true);
response.addCookie(c);
```

- ① 외부입력값을 쿠키에 설정하기 전에 HTTP응답분할을 대비한 안전한 필터링을 하고 있다.
- ② 쿠키에 설정된 만료시간이 과도하게 길게 설정되었다.
- ③ document.cookie와 같은 자바스크립트로 쿠키를 조회하는 것을 막을 수 있다.
- ④ http프로토콜로는 쿠키가 전송되지 않는다.

2) 답안

채점결과

①

2. 실습시험

가. 단순서술형 : 보안약점 정·오탐 분석 작성

1) 문제

① 암호화 기능 설계 시 안전한 암호 알고리즘을 사용하도록 설계되어 있는지 확인해야 한다. 국내외 사용 권고 알고리즘 중 대칭키와 비대칭키 암호화 알고리즘을 각각 2개씩을 기술하고, 대칭키와 비대칭키의 안전한 암호키 길이 (~bit 이상)도 각각 기술하시오.(2점)

② 그리고 서버 간에 큰 데이터를 빈번하게 송수신을 하면서 암호화 통신을 해야 하는 서비스 설계 시에 대칭키와 비대칭키 중 더 적합하게 적용이 가능한 방식을 선택하고 그 이유를 설명하시오.(3점)

2) 답안 (점수: 5점) ※ 빨간 글씨 반드시 포함되어야 정답 인정

채점결과

①

대칭키와 비대칭키 권고 알고리즘

- 대칭키 : SEED, ARIA, AES, Blowfish, Camelia, MISTY1, KASUMI
- 비대칭키 : RSA, KCDSA, RSAES-OAEP, ECC, ElGamel

안전한 암호키 길이

- 대칭키 암호키 길이: 128bit 이상
- 비대칭키 암호키 길이: 2048bit 이상

②

- 대칭키가 적합하다.

- 이유: 대칭키 방식이 비대칭키 방식보다 속도가 빠르다.
또는 비대칭키 방식이 연산이 많아 대칭키보다 속도가 느리다.

나. 복합사술형 : 보안약점 정·오탐 분석 및 보고서 작성

1) 문제 (총 8점)

회원정보 관리 프로세스를 설계하는 중에 비밀번호 관리에 대한 설계 문서를 보안성 검토를 하게 되었다. 요구사항 정의서, 아키텍처 설계서, 개발 가이드에 대해 보안성 검토를 하여, 맨 아래 취약점 진단 보고서를 작성하시오.
(전제 조건) ‘요구사항 정의서’의 내용은 이상없음

■ 요구사항 정의서

요구사항 ID	요구사항 명	구분	요구사항설명	요구사항 출처	제약 사항	중요도	해결방안	검수기준
SR-020301	안전한 비밀번호 생성규칙 적용	비기능	비밀번호를 설정할 때 한국 인터넷진흥원의 「암호 이용안내서」의 비밀번호 생성규칙을 적용해야 한다.	RFP 보안요구 사항 2.3	없음	상	암호이용안내서의 비밀번호 생성칙을 적용한다.	암호이용 안내서의 비밀번호 생성규칙을 따른다.
SR-020302	네트워크로 비밀번호 전송 시 암호화	비기능	네트워크를 통해 비밀번호를 전송하는 경우 반드시 비밀번호를 암호화 하거나 암호화된 통신 채널을 이용해야 한다.	RFP 보안요구 사항 2.3	없음	상	로그인, 회원정보수정 등 비밀번호 정보를 포함하는 요청은 HTTPS로 처리한다.	비밀번호 정보가 포함된 요청은 HTTP로 처리되지 않고 HTTPS로 처리된다.
SR-020303	비밀번호 저장 시 솔트가 적용된 안전한 해시함수 사용	비기능	비밀번호 저장 시, 솔트가 적용된 안전한 해시함수를 사용해야 하며, 해시함수 실행은 서버에서 해야 한다.	RFP 보안요구 사항 2.3	없음	상	해시를 추출하는 공통 모듈 구현 시 임의의 난수를 생성하여 솔트를 사용하고, 해시값과 함께 반환하도록 한다.	해시를 추출할 때 난수 형태의 솔트가 적용되고 사용한 솔트를 확인할 수 있다.
SR-020304	비밀번호 재설정/변경 시 안전한 변경 규칙 적용	비기능	비밀번호 재설정/변경 시 안전하게 변경할 수 있는 규칙을 정의해서 적용해야 한다.	RFP 보안요구 사항 2.3	없음	상	항시 비밀번호 변경이 가능하도록 하고, 동일 비밀번호를 장기간 사용하는 경우 3개월 주기로 비밀번호를 변경하도록 강제한다. 비밀번호를 분실한 경우, 비밀번호 찾기 기능의 안전한 절차를 통해서 임시 비밀번호를 발급한다.	비밀번호 변경, 3개월 주기로 변경, 친한 비밀번호 찾기 기능을 제공한다.
SR-020305	비밀번호 관리 규칙 적용	비기능	비밀번호 관리 규칙을 정의해서 적용해야 한다.	RFP 보안요구 사항 2.3	없음	상	비밀번호 변경주기를 3개월로 하고, 만료기간을 6개월로 한다.	비밀번호 변경주기와 만료기간 정책이 반영되었다.

■ 아키텍처 설계서

요구사항 ID SR-020301

요구사항 내용

비밀번호를 설정할 때 한국인터넷진흥원의 『암호이용안내서』의 비밀번호 생성규칙을 적용해야 한다.

구현방안

- ① 비밀번호는 영문자, 숫자, 특수문자를 조합하여 8글자 이상을 사용하도록 한다.
- ② 많이 사용하는 유형의 비밀번호를 DB에 등록하고, 입력한 비밀번호가 해당 유형에 포함되면 사용할 수 없도록 한다.
- ③ 전화번호와 같이 사용자의 신상정보가 포함된 비밀번호는 사용할 수 없도록 한다.
- ④ 동일 문자의 반복, 키보드의 배열과 같이 일정한 패턴을 포함한 비밀번호는 사용할 수 없도록 한다.

요구사항 ID SR-020302

요구사항 내용

네트워크로 비밀번호를 전송하는 경우 반드시 비밀번호를 암호화하거나 암호화된 통신 채널을 이용해야 한다.

구현방안

- ① 비밀번호 정보를 전달하는 기능을 도출한다.
 - 회원가입, 회원정보 변경, 로그인, ... 등
- ② 해당 기능은 HTTPS를 사용하여 스니핑과 같은 공격으로부터 데이터를 보호할 수 있도록 한다.
 - HTTP로 접속하는 경우, HTTPS로 자동 전환되도록 서버와 애플리케이션을 설정한다.

요구사항 ID SR-020303

요구사항 내용

비밀번호 저장 시, 솔트가 적용된 안전한 해시함수를 사용해야 하며, 서버의 부하를 최소화하기 위해서 클라이언트에서 해시함수를 실행한다.

구현방안

- ① 공통모듈로 해시를 추출하는 기능을 추가한다.
- ② 해시 추출 시 임의의 난수를 생성하여 솔트로 사용하도록 한다.
- ③ 추출된 해시값과 솔트를 반환하도록 한다.

요구사항 ID SR-020304

요구사항 내용

비밀번호 재설정/변경 시 안전하게 변경할 수 있는 규칙을 정의해서 적용해야 한다.

구현방안

- ① 사용자별 비밀번호 변경일시와 이전 비밀번호 정보를 관리한다.
- ② 마지막 비밀번호 변경일시가 3개월을 초과한 경우, 로그인과 동시에 비밀번호를 변경하도록 한다.
- ③ 비밀번호를 변경 시 비밀번호 이력을 참고하여 이전 비밀번호를 반복해서 사용할 수 없도록 한다.
- ④ 비밀번호 찾기를 요청하면, 회원 가입 시 입력한 이메일 주소로 임시 비밀번호를 전달한다.
- ⑤ 임시 비밀번호로 로그인한 경우에는 반드시 비밀번호를 변경 후 재 로그인하도록 한다.

요구사항 ID SR-020305

요구사항 내용

비밀번호 관리 규칙을 정의해서 적용해야 한다.

구현방안

- ① 사용자별 마지막 로그인 일시 정보를 관리한다.
- ② 비밀번호는 3개월 단위로 변경하도록 한다.
- ③ 6개월 동안 로그인하지 않은 계정은 만료 처리한다.

개발가이드

2.3.1. 비밀번호 생성 규칙

무작위대입 및 사전대입 공격을 방어하기 위해서는 다음의 생성 규칙에 따라 비밀번호를 생성하여야 한다.

- 세가지 유형의 문자(영문자, 숫자, 특수문자)를 조합하는 경우, 8자리 이상의 길이를 사용
- 두가지 유형의 문자를 조합하는 경우, 10자리 이상의 길이를 사용
- 비밀번호로 많이 사용되는 단어 사용 금지
- 전화번호와 같이 개인의 신상정보가 포함된 단어 사용 금지
- 반복 문자열, 키보드의 배열과 같이 일정한 규칙을 가진 문자열 사용 금지

공통모듈에 비밀번호 검증 기능을 추가하고, 비밀번호 생성 및 변경 시 검증 후 사용될 수 있도록 한다.

```
public static boolean checkPasswd(String password)
{
    if (null == password || password.equals("")) {
        return false;
    }

    if (password.trim().length() < 6) {
        LOG.info("[ValidatorUtil_checkPasswd()] checkPasswd MIN8!!");
        return false;
    }

    for (int i = 0; i < password.length(); i++) {
        char ch = password.charAt(i);
        if (! ((ch) = '0' && '9') = ch) || (ch) = 'a' && 'z' = ch)
            || (ch) = 'A' && 'Z' = ch)
            || ch == '!' || ch == '@' || ch == '$' || ch == '%'
            || ch == '^' || ch == '&' || ch == '*')) {
            LOG.info("password not [" + ch + " ]!");
            return false;
        }
    }
    return true;
}
```

2.3.2. 비밀번호 전송 규칙

로그인, 회원가입, 회원정보 변경과 같이 비밀번호 정보를 전송해야 하는 경우, HTTPS와 같은 안전한 통신 채널을 이용하여 전송하여야 한다.

이때, HTTP 프로토콜로 접속하더라도 HTTPS로 리다이렉트되도록 서버와 애플리케이션을 설정하여야 한다.

```
# Apache httpd.conf
<VirtualHost xxx.xxx.xxx.xxx:80>
    RewriteEngine On
    RewriteCond % {HTTPS} off
    RewriteRule (.*?) https://% {HTTP_HOST} % {REQUEST_URI}
</VirtualHost>
```

만약, 안전한 통신 채널을 이용할 수 없는 경우에는 안전한 암호화 방식으로 암호화하여 전송하여야 한다.

2.3.3. 비밀번호 저장

비밀번호는 개인정보보호법, 정보통신망법에서 일방향 해시로 암호화하여 저장하도록 규정하고 있다. 해시를 사용할 경우에는 SHA2 이상의 알고리즘을 사용하여야 하며, 해시의 크래킹을 방어하기 위해 솔트를 반드시 적용하여야 한다.

```
public String getPasswordHash(String password, byte[] salt) throws Exception
{
    MessageDigest md = MessageDigest.getInstance("SHA-256");
    md.update(password.getBytes());
    md.update(salt);
    byte byteData[] = md.digest();
    StringBuffer hexString = new StringBuffer();
    for (int i=0;i<byteData.length i++) {
        String hex=Integer.toHexString(0xff & byteData[i]);
        if (hex.length() == 1) {
            hexString.append('0');
        }
        hexString.append(hex);
    }
    return hexString.toString();
}
```

2.3.4. 비밀번호 재설정 및 변경

로그인한 사용자는 언제든지 비밀번호를 변경할 수 있도록 기능을 제공해야 하며, 장기간 비밀번호를 변경하지 않고 사용자에 대해서는 3개월~6개월 단위로 비밀번호 변경을 유도해야 한다.

비밀번호 변경 시 이전 비밀번호 이력을 조회하여 이전 비밀번호를 연속해서 사용하는 것을 막아야 하며, 비밀번호 변경 시에도 비밀번호 생성 규칙과 동일 규칙을 적용해야 한다.

사용자가 비밀번호를 분실한 경우, 비밀번호 찾기 기능으로 비밀번호를 재설정할 수 있도록 해야 한다.

비밀번호 찾기는 찾기 기능 버튼 클릭시 팝업 창에서 입력 받은 이메일 주소로 임시 비밀번호를 발송하며, 사용자는 임시 비밀번호로 로그인할 수 있다.

임시 비밀번호로 로그인한 경우, 반드시 비밀번호를 변경 후 다시 로그인하도록 해야 한다.

2.3.5. 비밀번호 관리 규칙

비밀번호는 다음의 관리 규칙에 따라 관리되어야 한다.

- 비밀번호는 3개월~6개월 간격으로 변경해야 한다.
- 비밀번호 변경 이력을 관리하고, 이전 비밀번호를 연속해서 사용할 수 없도록 해야 한다.
- 최소사용기간 정책에 따라 비밀번호 변경 후 일정 기간 동안 비밀번호를 변경할 수 없도록 해야 한다.
- 마지막 로그인 시간을 관리하고, 일정 기간 동안 로그인하지 않는 사용자의 계정은 만료 처리해야 한다.

■ 보안 요청서(문제지)

보안 약점	유형	보안기능
	한글명	2-3. 비밀번호 관리
	설명	비밀번호 생성규칙, 저장방법, 변경주기 등 비밀번호 관리 정책별 안전한 적용방법을 설계해야 한다.
보안 요구사항	1. 비밀번호 관리 규칙을 정의해서 적용해야 한다. 2. 비밀번호 변경주기, 만료기간 설정, 성공한 로그인 시간 관리를 포함하여 비밀번호 관리규칙이 설계되어 있는지 확인한다.	
현황 및 문제점	① (4점) 문제 원인:	
해결 방안	② (4점) 해결 방안:	

2) 답안 (점수: 8점)

■ 보안 요청서(답안지) ※ 빨간 글씨 반드시 포함되어야 정답 인정

• 보완요청서

보안 약점	유형	보안기능
	한글명	2-3. 비밀번호 관리
	설명	비밀번호 생성규칙, 저장방법, 변경주기 등 비밀번호 관리 정책별 안전한 적용방법을 설계해야 한다.
보안 요구사항	1. 비밀번호 관리 규칙을 정의해서 적용해야 한다. 2. 비밀번호 변경주기, 만료기간 설정, 성공한 로그인 시간 관리를 포함하여 비밀번호 관리규칙이 설계되어 있는지 확인한다.	
현황 및 문제점	① (4점) 문제 원인: 개발가이드 '2.3.1. 비밀번호 생성 규칙'에서 비밀번호 최소길이가 8자리임에도 공통 모듈의 소스가 잘못되어서 "if (password.trim().length() < 6)"로 인해 6자리도 통과가 된다.	
해결 방안	② (4점) 해결 방안: 공통모듈의 비밀번호 조건절 을 "if (password.trim().length() < 8)"처럼 8자리로 체크하도록 수정한다.	

• 진단 보고서 (진단 보고서 작성이 필요한 경우 아래와 같은 양식으로 문제지 및 답안 작성)

진단대상	회원정보 관리 프로세스를 설계
분류	☐ 입력데이터 검증 및 표현 ☒ 보안기능 ☐ 에러처리 ☐ 세션통제
보안설계 기준	2-3. 비밀번호 관리
설명	비밀번호 생성규칙, 저장방법, 변경주기 등 비밀번호 관리 정책별 안전한 적용방법을 설계해야 한다.
진단결과	☒ Y ☐ N
현황 및 문제점	(4점) 개발가이드 '2.3.1. 비밀번호 생성 규칙'에서 비밀번호 최소길이가 8자리임에도 공통 모듈의 소스가 잘못되어서 "if (password.trim().length() < 6)"로 인해 6자리도 통과가 된다.
관련 산출물	요구사항분석서, 유즈케이스명세서, 아키텍처정의서, ...
증적자료	〈생략〉
개선방안	(4점) 공통모듈의 비밀번호 조건절 을 "if (password.trim().length() < 8)"처럼 8자리로 체크하도록 수정한다.
이행담당자	홍길동
보완조치 내역	〈생략〉

붙임 3 소프트웨어 보안약점 기준

1. (설계단계) 보안설계기준

구분	설계항목	설 명
입력 데이터 검증 및 표현	DBMS 조회 및 결과 검증	DBMS 조회시 질의문(SQL) 내 입력값과 그 조회결과에 대한 유효성 검증방법 (필터링 등) 설계 및 유효하지 않은 값에 대한 처리방법 설계
	XML 조회 및 결과 검증	XML 조회시 질의문(XPath, XQuery 등) 내 입력값과 그 조회결과에 대한 유효성 검증방법(필터링 등) 설계 및 유효하지 않은 값에 대한 처리방법 설계
	디렉토리 서비스 조회 및 결과 검증	디렉토리 서비스(LDAP 등)를 조회할 때 입력값과 그 조회결과에 대한 유효성 검증 방법 설계 및 유효하지 않은 값에 대한 처리방법 설계
	시스템 자원 접근 및 명령어 수행 입력값 검증	시스템 자원접근 및 명령어를 수행할 때 입력값에 대한 유효성 검증방법 설계 및 유효하지 않은 값에 대한 처리방법 설계
	웹 서비스 요청 및 결과 검증	웹 서비스(게시판 등) 요청(스크립트 게시 등)과 응답결과(스크립트를 포함한 웹 페이지)에 대한 유효성 검증방법 설계 및 유효하지 않은 값에 대한 처리방법 설계
	웹 기반 중요 기능 수행 요청 유효성 검증	비밀번호 변경, 결제 등 사용자 권한 확인이 필요한 중요기능을 수행할 때 웹 서비스 요청에 대한 유효성 검증방법 설계 및 유효하지 않은 값에 대한 처리방법 설계
	HTTP 프로토콜 유효성 검증	비정상적인 HTTP 헤더, 자동연결 URL 링크 등 사용자가 원하지 않은 결과를 생성 하는 HTTP 헤더 응답결과에 대한 유효성 검증방법 설계 및 유효하지 않은 값에 대한 처리방법 설계
	허용된 범위내 메모리 접근	해당 프로세스에 허용된 범위의 메모리 버퍼에만 접근하여 읽기 또는 쓰기 기능을 하도록 검증방법 설계 및 메모리 접근요청이 허용범위를 벗어났을 때 처리방법 설계
	보안기능 입력값 검증	보안기능(인증, 권한부여 등) 입력 값과 함수(또는 메소드)의 외부입력 값 및 수행결과에 대한 유효성 검증방법 설계 및 유효하지 않은 값에 대한 처리방법 설계
	업로드·다운로드 파일 검증	업로드·다운로드 파일의 무결성, 실행권한 등에 관한 유효성 검증방법 설계 및 부적합한 파일에 대한 처리방법 설계
보안기능	인증 대상 및 방식	중요정보·기능의 특성에 따라 인증방식을 정의하고 정의된 인증방식을 우회하지 못하게 설계
	인증 수행 제한	반복된 인증 시도를 제한하고 인증 실패한 이력을 추적하도록 설계
	비밀번호 관리	생성규칙, 저장방법, 변경주기 등 비밀번호 관리정책별 안전한 적용방법 설계
	중요자원 접근통제	중요자원(프로그램 설정, 민감한 사용자 데이터 등)을 정의하고, 정의된 중요 자원에 대한 신뢰할 수 있는 접근통제 방법(권한관리 포함) 설계 및 접근통제 실패 시 처리방법 설계
	암호키 관리	암호키 생성, 분배, 접근, 파기 등 암호키 생명주기별 암호키 관리방법을 안전하게 설계
	암호연산	국제표준 또는 검증필 암호모듈로 등재된 안전한 암호 알고리즘을 선정하고 충분한 암호키 길이, 솔트, 충분한 난수 값을 적용한 안전한 암호연산 수행방법 설계
	중요정보 저장	중요정보(비밀번호, 개인정보 등)를 저장·보관하는 방법이 안전하도록 설계
	중요정보 전송	중요정보(비밀번호, 개인정보, 쿠키 등)를 전송하는 방법이 안전하도록 설계
에러처리	예외처리	오류메시지에 중요정보(개인정보, 시스템 정보, 민감 정보 등)가 노출되거나, 부적절한 에러·오류 처리로 의도치 않은 상황이 발생하지 않도록 설계
세션통제	세션통제	다른 세션 간 데이터 공유금지, 세션ID 노출금지, (재)로그인시 기존 세션ID 재사용 금지 등 안전한 세션 관리방안 설계

2. (구현단계) 보안약점 제거 기준

구분	보안약점	설 명
입력 데이터 검증 및 표현	SQL 삽입	SQL 질의문을 생성할 때 검증되지 않은 외부 입력 값을 허용하여 악의적인 질의문이 실행가능한 보안약점
	코드 삽입	프로세스가 외부 입력 값을 코드(명령어)로 해석·실행할 수 있고 프로세스에 검증되지 않은 외부 입력 값을 허용한 경우 악의적인 코드가 실행 가능한 보안약점
	경로 조작 및 자원 삽입	시스템 자원 접근경로 또는 자원제어 명령어에 검증되지 않은 외부 입력 값을 허용하여 시스템 자원에 무단 접근 및 악의적인 행위가 가능한 보안약점
	크로스사이트 스크립트	사용자 브라우저에 검증되지 않은 외부 입력값을 허용하여 악의적인 스크립트가 실행 가능한 보안약점
	운영체제 명령어 삽입	운영체제 명령어를 생성할 때 검증되지 않은 외부 입력값을 허용하여 악의적인 명령어가 실행 가능한 보안약점
	위험한 형식 파일 업로드	파일의 확장자 등 파일형식에 대한 검증없이 파일 업로드를 허용하여 공격이 가능한 보안약점
	신뢰되지 않는 URL 주소로 자동접속 연결	URL 링크 생성에 검증되지 않은 외부 입력값을 허용하여 악의적인 사이트로 자동 접속 가능한 보안약점
	부적절한 XML 외부 개체 참조	임의로 조작된 XML 외부개체에 대한 적절한 검증 없이 참조를 허용하여 공격이 가능한 보안약점
	XML 삽입	XQuery, XPath 질의문을 생성할 때 검증되지 않은 외부 입력값을 허용하여 악의적인 질의문이 실행가능한 보안약점
	LDAP 삽입	LDAP 명령문을 생성할 때 검증되지 않은 외부 입력 값을 허용하여 악의적인 명령어가 실행가능한 보안약점
	크로스사이트 요청 위조	사용자 브라우저에 검증되지 않은 외부 입력 값을 허용하여 사용자 본인의 의지와는 무관하게 공격자가 의도한 행위가 실행 가능한 보안약점
	서버사이드 요청 위조	서버 간 처리되는 요청에 검증되지 않은 외부 입력값을 허용하여 공격자가 의도한 서버로 전송하거나 변조하는 보안약점
	HTTP 응답분할	HTTP 응답헤더에 개행문자(CR이나 LF)가 포함된 검증되지 않은 외부 입력값을 허용하여 악의적인 코드가 실행 가능한 보안약점
	정수형 오버플로우	정수형 변수에 저장된 값이 허용된 정수 값 범위를 벗어나 프로그램이 예기치 않게 동작 가능한 보안약점
	보안기능 결정에 사용되는 부적절한 입력값	보안기능(인증, 권한부여 등) 결정에 검증되지 않은 외부 입력값을 허용하여 보안기능을 우회하는 보안약점

메모리 버퍼 오버플로우	메모리 버퍼의 경계값을 넘어서 메모리값을 읽거나 저장하여 예기치 않은 결과가 발생하는 보안약점
포맷 스트링 삽입	printf 등 포맷 스트링 제어함수에 검증되지 않은 외부 입력값을 허용하여 발생하는 보안약점 * 포맷 스트링: 입·출력에서 형식이나 형태를 지정해주는 문자열

구분	보안약점	설 명
보안 기능	적절한 인증 없는 중요기능 허용	중요정보(금융정보, 개인정보, 인증정보 등)를 적절한 인증없이 열람 (또는 변경) 가능한 보안약점
	부적절한 인가	중요자원에 접근할 때 적절한 제어가 없어 비인가자의 접근이 가능한 보안약점
	중요한 자원에 대한 잘못된 권한 설정	중요자원에 적절한 접근 권한을 부여하지 않아 중요정보가 노출·수정 가능한 보안약점
	취약한 암호화 알고리즘 사용	중요정보(금융정보, 개인정보, 인증정보 등)의 기밀성을 보장할 수 없는 취약한 암호화 알고리즘을 사용하여 정보가 노출 가능한 보안약점
	암호화되지 않은 중요정보	중요정보(비밀번호, 개인정보 등) 전송 시 암호화 또는 안전한 통신 채널을 이용하지 않거나, 저장 시 암호화하지 않아 정보가 노출 가능한 보안약점
	하드코딩된 중요정보	소스코드에 중요정보(비밀번호, 암호화키 등)를 직접 코딩하여 소스코드 유출 시 중요정보가 노출되고 주기적 변경이 어려운 보안약점
	충분하지 않은 키 길이 사용	암호화 등에 사용되는 키의 길이가 충분하지 않아 데이터의 기밀성· 무결성을 보장할 수 없는 보안약점
	적절하지 않은 난수 값 사용	사용한 난수가 예측 가능하여, 공격자가 다음 난수를 예상해서 시스템을 공격 가능한 보안약점
	취약한 비밀번호 허용	비밀번호 조합규칙(영문, 숫자, 특수문자 등) 미흡 및 길이가 충분하지 않아 비밀번호가 노출 가능한 보안약점
	부적절한 전자서명 확인	프로그램, 라이브러리, 코드의 전자서명에 대한 유효성 검증이 적절하지 않아 공격자의 악의적인 코드가 실행 가능한 보안약점
	부적절한 인증서 유효성 검증	인증서에 대한 유효성 검증이 적절하지 않아 발생하는 보안약점
	사용자 하드디스크에 저장되는 쿠키를 통한 정보 노출	쿠키(세션 ID, 사용자 권한정보 등 중요정보)를 사용자 하드디스크에 저장되어 중요정보가 노출 가능한 보안약점
	주석문 안에 포함된 시스템 주요정보	소스코드 주석문에 인증정보 등 시스템 주요정보가 포함되어 소스코드 노출 시 주요정보도 노출 가능한 보안약점
	솔트 없이 일방향 해쉬 함수사용	솔트*를 사용하지 않고 생성된 해쉬 값으로부터 공격자가 미리 계산된 레인보우 테이블을 이용하여 해쉬 적용 이전 원본 정보를 복원가능한 보안약점 * 해쉬 적용하기 전 평문인 전송정보에 덧붙인 무의미한 데이터
	무결성 검사없는 코드 다운로드	소스코드 또는 실행파일을 무결성 검사 없이 다운로드 받아 실행하는 경우, 공격자의 악의적인 코드가 실행 가능한 보안약점
	반복된 인증시도 제한 기능 부재	인증 시도 수를 제한하지 않아 공격자가 반복적으로 임의 값을 입력하여 계정 권한을 획득 가능한 보안약점

구분	보안약점	설 명
시간 및 상태	경쟁조건: 검사 시점과 사용 시점 (TOCTOU)	멀티 프로세스 상에서 자원을 검사하는 시점과 사용하는 시점이 달라서 발생하는 보안약점
	종료되지 않는 반복문 또는 재귀 함수	종료조건 없는 제어문 사용으로 반복문 또는 재귀함수가 무한히 반복 되어 발생할 수 있는 보안약점
에러 처리	오류 메시지 정보노출	오류메시지나 스택정보에 시스템 내부구조가 포함되어 민감한 정보, 디버깅 정보가 노출 가능한 보안약점
	오류상황 대응 부재	시스템 오류상황을 처리하지 않아 프로그램 실행정지 등 의도하지 않은 상황이 발생 가능한 보안약점
	부적절한 예외 처리	예외사항을 부적절하게 처리하여 의도하지 않은 상황이 발생 가능한 보안약점
코드 오류	Null Pointer 역참조	변수의 주소 값이 Null인 객체를 참조하는 보안약점
	부적절한 자원 해제	사용 완료된 자원을 해제하지 않아 자원이 고갈되어 새로운 입력을 처리할 수 없는 보안약점
	해제된 자원 사용	메모리 등 해제된 자원을 참조하여 예기치 않은 오류가 발생하는 보안약점
	초기화되지 않은 변수 사용	변수를 초기화하지 않고 사용하여 예기치 않은 오류가 발생하는 보안약점
	신뢰할 수 없는 데이터의 역직렬화	악의적인 코드가 삽입·수정된 직렬화 데이터를 적절한 검증 없이 역직렬화 하여 발생하는 보안약점 *직렬화: 객체를 전송 가능한 데이터형식으로 변환 *역직렬화: 직렬화된 데이터를 원래 객체로 복원
캡슐화	잘못된 세션에 의한 데이터 정보 노출	잘못된 세션에 의해 인가되지 않은 사용자에게 중요정보가 노출 가능한 보안약점
	제거되지 않고 남은 디버그 코드	디버깅을 위한 코드를 제거하지 않아 인가되지 않은 사용자에게 중요정 보가 노출 가능한 보안약점
	Public 메소드부터 반환된 Private 배열	Public으로 선언된 메소드에서 Private로 선언된 배열을 반환(return)하면 Private 배열의 주소 값이 외부에 노출되어 해당 Private 배열값을 외부에서 수정 가능한 보안약점
	Private 배열에 Public 데이터 할당	Public으로 선언된 데이터 또는 메소드의 인자가 Private으로 선언된 배열에 저장되면 이 Private 배열을 외부에서 접근하여 수정 가능한 보안약점
API 오용	DNS lookup에 의존한 보안결정	도메인명 확인(DNS lookup)으로 보안결정을 수행할 때 악의적으로 변조된 DNS 정보로 예기치 않은 보안위협에 노출되는 보안약점
	취약한 API 사용	취약한 함수를 사용해서 예기치 않은 보안위협에 노출되는 보안약점